



**Politecnico
di Torino**

Politecnico di Torino

Master's Degree Course in Cybersecurity

Academic Year 2025/2026

Graduation Session October 2026

Design of an Agent-Based Framework for Vulnerability Detection and Classification in Open-Source Software Repositories

Supervisors:

Matteo Boffa
Idilio Drago

Candidate:

Alessandro Medvescek

Table of Contents

List of Tables	III
List of Figures	IV
1 Introduction	1
1.1 Problem & Motivation	1
1.2 Thesis Organization	2
2 Background	3
2.1 Goal	3
2.2 Struttura della tesi	4
Bibliography	5

List of Tables

List of Figures

Chapter 1

Introduction

1.1 Problem & Motivation

Open-source software is the foundation of modern computing. Individual users and companies alike rely on openly available source code, maintained by communities of volunteers and by companies alike. Open-source has become effectively universal: about 98% of the audited codebases contain open source components [1].

Open-source security is a double-edged sword: while extreme transparency enables faster bug detection and patching by the community, it also provides attackers with everything they needed to hunt for vulnerabilities. In addition, Open-source dependencies are nested in the majority of software projects, leading to possible supply-chain attacks.

The most important and known service in term of OSS¹ is GitHub: a global platform for software development based on version control and collaboration. It contains countless open-source repositories where developers can share and review code. At the base of the platform there is the concept of commit: a snapshot of the source code at a specific point of time. The direct consequence of the structure of this framework is the possibility of inspecting any change made to the repository as soon as it is published. The nature of the commit can be various, from bug correction to code refactoring. For the scope of this thesis, the attention will be posed on security updates.

Security fixes, however, do not reach the public in the same way as ordinary changes. Under the CVD² model, a vulnerability is corrected before it is announced, so that a remedy already exists by the time users learn that they are at risk. During this embargo period the fix is committed like any other change, but the commit

¹OSS stands for open-source software.

²CVD stands for Coordinated Vulnerability Disclosure.

message is kept vague or generic, so that the change does not attract the attention of anyone watching the repository [2]. All of this happens inside the window of exposure, which opens when the flaw is discovered and closes only once the correction has been distributed and applied. What makes this period peculiar is that the code repairing the flaw is public and readable by anyone from the moment it is pushed, while the information needed to recognise it as a security fix is not.

Between the moment a fix is written and the moment it actually protects anyone there are two distinct delays [3]. The first one lies between the commit and the release: the correction is already in the repository, but it only becomes installable when the maintainers publish a new version of the package. The second one lies between that release and the publication of a security advisory, which is what tells the automated tools used by client projects that they should update. In both cases the code of the fix is already public, while the projects that depend on it are still exposed and have no way of knowing it.

This practice is known as a silent patch: the vulnerability is fixed, but nothing in the commit says that a vulnerability was ever there. A direct consequence is that users keep running vulnerable software, because they receive no signal telling them that a specific update matters more than the others. Outdated code is the norm rather than the exception: one study of more than 4,600 GitHub projects found that 81.5% of them kept dependencies that were no longer up to date [4], and about 92% of the audited codebases contain components that are ten or more versions behind the current release [1]. A silent patch therefore lands on a population of projects that is already far behind, and does nothing to tell them that this time they should hurry.

1.2 Thesis Organization

Chapter 2

Background

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Porttitor eget dolor morbi non arcu risus quis varius. Libero id faucibus nisl tincidunt. Neque laoreet suspendisse interdum consectetur libero id faucibus nisl tincidunt. Scelerisque in dictum non consectetur a erat. Leo a diam sollicitudin tempor id eu. Sodales ut eu sem integer vitae justo eget magna fermentum. A cras semper auctor neque vitae. Cursus euismod quis viverra nibh cras pulvinar. Mi tempus imperdiet nulla malesuada pellentesque elit eget gravida cum. Dictum at tempor commodo ullamcorper a lacus vestibulum sed. Ultricies mi eget mauris pharetra. In pellentesque massa placerat dui ultricies lacus. Fringilla phasellus faucibus scelerisque eleifend donec pretium vulputate.

Aliquam sem fringilla ut morbi tincidunt augue interdum. Risus at ultrices mi tempus imperdiet nulla malesuada pellentesque. Semper quis lectus nulla at volutpat. Nullam non nisi est sit amet facilisis. Eget velit aliquet sagittis id consectetur purus ut faucibus pulvinar. Ultricies tristique nulla aliquet enim tortor at auctor urna nunc. Pharetra diam sit amet nisl suscipit adipiscing bibendum est ultricies. Amet facilisis magna etiam tempor. Nunc non blandit massa enim nec dui nunc mattis. At ultrices mi tempus imperdiet nulla malesuada pellentesque. Cursus metus aliquam eleifend mi in nulla posuere. In eu mi bibendum neque egestas congue quisque. Augue eget arcu dictum varius dui at consectetur.

2.1 Goal

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Tristique senectus et netus et malesuada fames ac turpis. Pretium nibh ipsum consequat nisl vel pretium lectus quam. Urna molestie at elementum eu facilisis sed odio morbi quis. Sed egestas egestas fringilla

phasellus faucibus scelerisque eleifend. At in tellus integer feugiat. Mauris rhoncus aenean vel elit scelerisque mauris pellentesque pulvinar. Commodos egestas egestas fringilla. Nunc lobortis mattis aliquam faucibus purus in massa. Facilisis magna etiam tempor orci eu lobortis elementum nibh. Elementum curabitur vitae nunc sed velit dignissim. Neque volutpat ac tincidunt vitae. Massa id neque aliquam vestibulum morbi blandit cursus risus at. Porta non pulvinar neque laoreet suspendisse interdum consectetur. Turpis in eu mi bibendum. Ut tristique et egestas quis ipsum suspendisse. Integer quis auctor elit sed vulputate mi sit amet. Viverra nam libero justo laoreet sit amet cursus.

2.2 Struttura della tesi

Lorem ipsum dolor sit amet:

- onsectetur adipiscing elit,
- sed do eiusmod tempor incididunt ut labore et dolore magna aliqua.
- Tristique senectus et netus et malesuada fames ac turpis.

Bibliography

- [1] Black Duck Software. *Open Source Security and Risk Analysis Report*. Annual report. Black Duck Software, Inc., 2026. URL: <https://www.blackduck.com/content/dam/black-duck/en-us/reports/rep-ossra.pdf> (visited on 08/09/2026) (cit. on pp. 1, 2).
- [2] Jiayuan Zhou, Michael Pacheco, Jinfu Chen, Xing Hu, Xin Xia, David Lo, and Ahmed E. Hassan. «CoLeFunDa: Explainable Silent Vulnerability Fix Identification». In: *Proceedings of the 45th IEEE/ACM International Conference on Software Engineering (ICSE)*. Melbourne, Australia: IEEE, 2023, pp. 2565–2577. DOI: 10.1109/ICSE48619.2023.00214 (cit. on p. 2).
- [3] Nasif Imtiaz, Aniq Khanom, and Laurie Williams. «Open or Sneaky? Fast or Slow? Light or Heavy?: Investigating Security Releases of Open Source Packages». In: *IEEE Transactions on Software Engineering* 49.4 (Apr. 2023), pp. 1540–1560. DOI: 10.1109/TSE.2022.3181010 (cit. on p. 2).
- [4] Jessy Ayala, Yu-Jye Tung, and Joshua Garcia. *Investigating Vulnerability Disclosures in Open-Source Software Using Bug Bounty Reports and Security Advisories*. 2025. arXiv: 2501.17748 [cs.CR]. URL: <https://arxiv.org/abs/2501.17748> (cit. on p. 2).